

Documentation : Audit de sécurité Active Directory (SAMBA-AD) avec PingCastle.

1. Présentation de l'outil

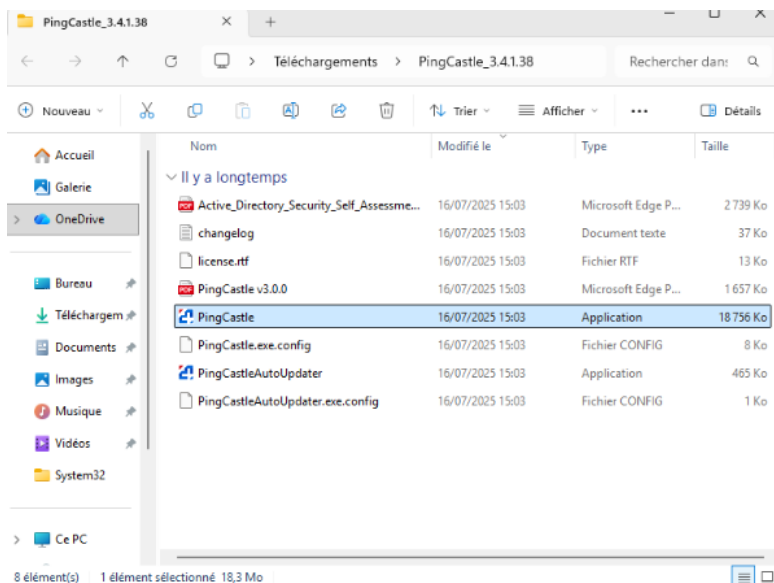
PingCastle est un outil de référence pour auditer la sécurité d'un domaine Active Directory (AD). Il évalue le niveau de risque global et détaille les vulnérabilités par catégories afin de proposer un plan d'action correctif.

2. Préparation et Lancement

L'outil se présente sous la forme d'une archive contenant un exécutable Windows. Il doit être lancé depuis un poste joint au domaine (ex: Windows 11) avec des privilèges d'administration pour un scan complet.

Procédure de lancement :

1. **Extraction** : Décompressez l'archive PingCastle_3.4.1.38.zip.
2. **Exécution** : Lancez le programme via le fichier PingCastle.exe.



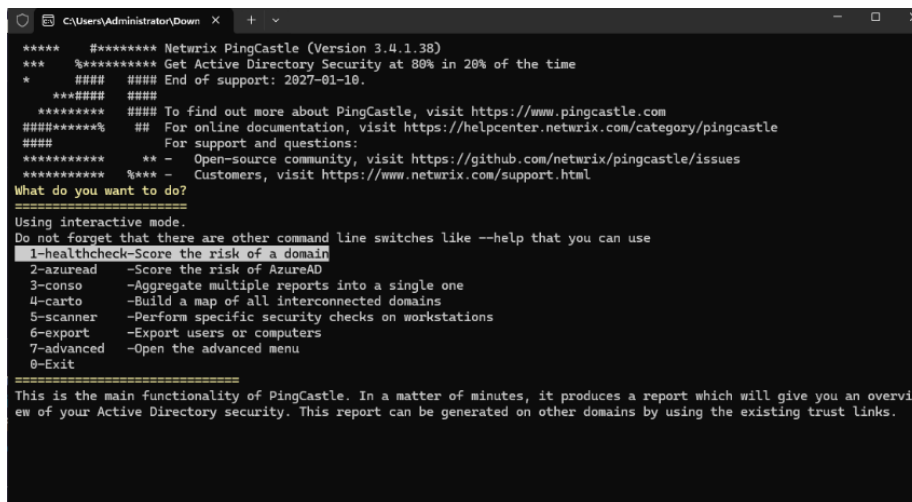
3. Configuration du Scan (Interactif)

Une fois lancé, l'outil propose un menu interactif dans une console. Voici les étapes à suivre selon vos captures :

Étape 1 : Choix de la fonctionnalité

Sélectionnez l'option principale pour évaluer le risque du domaine.

- **Action** : Tapez 1
- **Commande** : 1-healthcheck-Score the risk of a domain



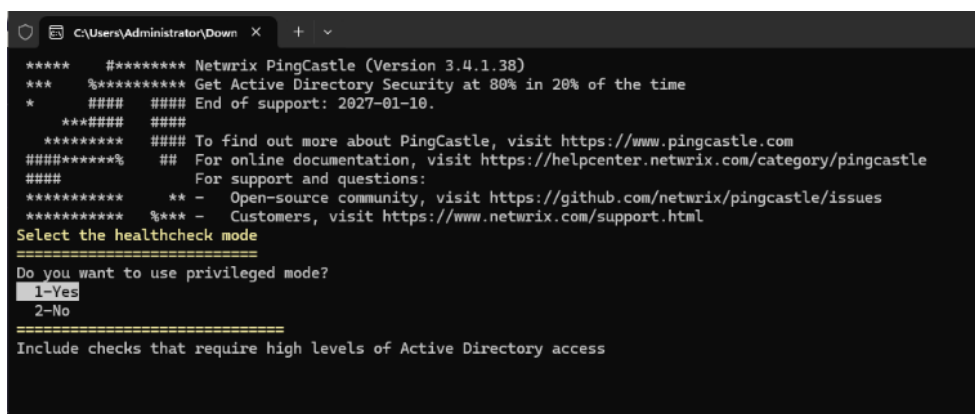
```
C:\Users\Administrator\Down X + v
**** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html

What do you want to do?
=====
Using interactive mode.
Do not forget that there are other command line switches like --help that you can use
1-healthcheck-Score the risk of a domain
2-azuread -Score the risk of AzureAD
3-conso -Aggregate multiple reports into a single one
4-carto -Build a map of all interconnected domains
5-scanner -Perform specific security checks on workstations
6-export -Export users or computers
7-advanced -Open the advanced menu
0-Exit
=====
This is the main functionality of PingCastle. In a matter of minutes, it produces a report which will give you an overview of your Active Directory security. This report can be generated on other domains by using the existing trust links.
```

Étape 2 : Mode de privilèges

Pour obtenir tous les détails techniques, activez le mode privilégié.

- **Action** : Tapez 1
- **Commande** : 1-Yes (Include checks that require high levels of Active Directory access)



```
C:\Users\Administrator\Down X + v
**** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html

Select the healthcheck mode
=====
Do you want to use privileged mode?
1-Yes
2-No
=====
Include checks that require high levels of Active Directory access
```

Étape 3 : Sélection du domaine

Spécifiez le domaine à analyser. Par défaut, l'outil détecte celui de votre session.

- **Action** : Appuyez sur **Entrée** pour valider le domaine par défaut.
- **Cible** : stage.local

```
C:\Users\Administrator\Down X + v

***** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
***** #####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html

Select a domain or server
=====
Please specify the domain or server to investigate (default:lab.local)
|
```

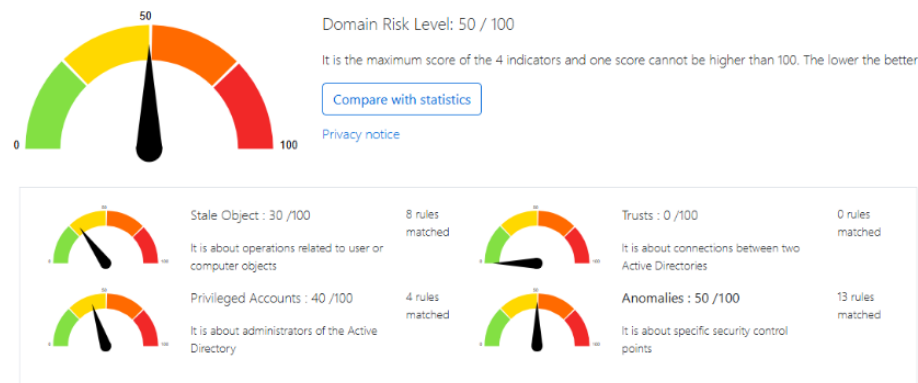
```
C:\Users\Administrator\Down X + v

***** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
***** #####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html

Select a domain or server
=====
Please specify the domain or server to investigate (default:lab.local)

Free Edition of PingCastle - Not for commercial use
Starting the task: Perform analysis for lab.local
[09:15:33] Getting domain information (lab.local)
Performance warning: using LDAP instead of ADWS
[09:15:39] Gathering general data
[09:15:41] Gathering user data
[09:15:41] Gathering computer data
[09:15:41] Gathering trust data
[09:15:41] Gathering privileged group and permissions data
[09:15:41] - Initialize
[09:15:41] - Searching for critical and infrastructure objects
[09:15:41] - Collecting objects - Iteration 1
```

Indicators



Domain Risk Level : 50 / 100. Le domaine se situe à la limite de la zone orange, ce qui signifie qu'il existe des vulnérabilités significatives nécessitant une intervention pour sécuriser l'annuaire.

Indicateur le plus critique : Anomalies (50 / 100). C'est le point le plus préoccupant avec **13 règles détectées**. Cela concerne des configurations techniques non conformes, des protocoles obsolètes ou des écarts de sécurité spécifiques au sein de l'environnement Samba4.

Comptes privilégiés (40 / 100) : PingCastle a détecté **4 règles** correspondant à des risques sur les comptes administrateurs. Cela indique souvent une surface d'attaque trop large sur les accès à hauts privilèges (ex: trop de Domain Admins ou mots de passe persistants).

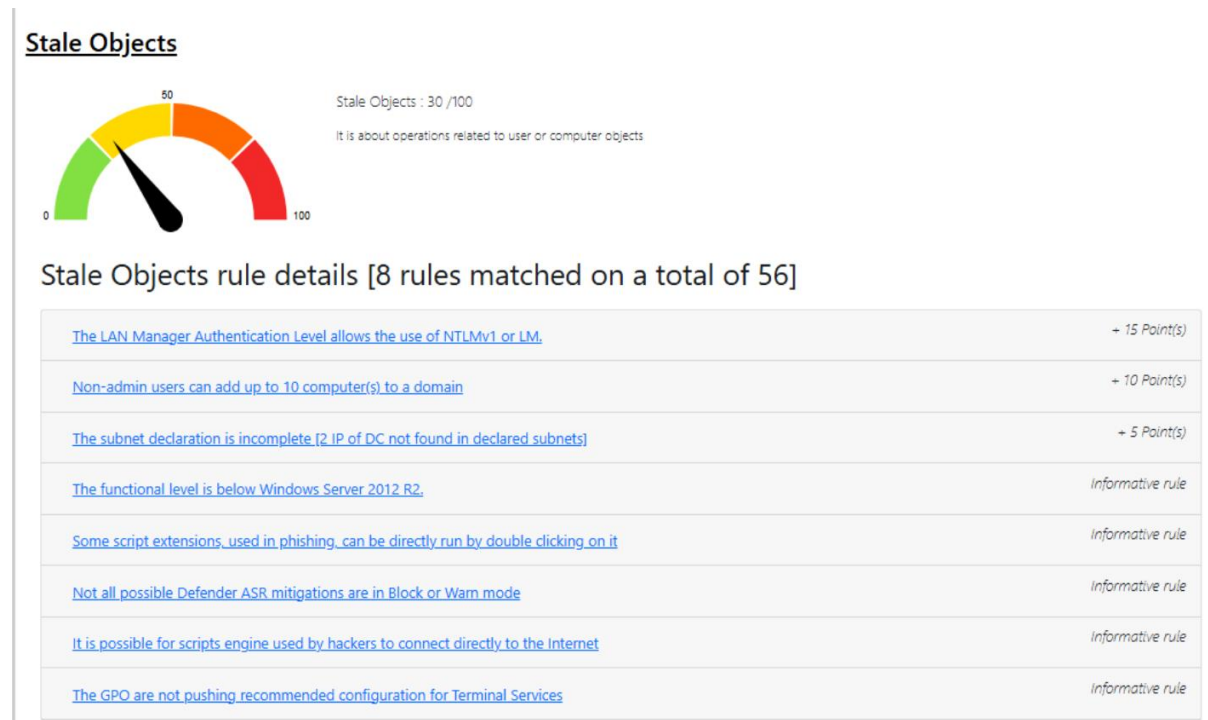
Stale Objects (30 / 100) : Cet indicateur relève **8 règles** liées à l'hygiène de l'Active Directory. Des comptes utilisateurs ou des machines inactives depuis longtemps n'ont pas été nettoyés, ce qui offre des opportunités de persistance pour un attaquant.

Stale Objects	Privileged accounts	Trusts	Anomalies
Inactive user or computer	Account take over	Old trust protocol	Audit
Network topography	ACL Check	SID Filtering	Backup
Object configuration	Admin control	SIDHistory	Certificate take over
Obsolete OS	Control paths	Trust impermeability	Golden ticket
Old authentication protocols	Delegation Check	Trust inactive	Local group vulnerability
Provisioning	Irreversible change	Trust with Azure	Network sniffing
Replication	Privilege control		Pass-the-credential
Vulnerability management	Read-Only Domain Controllers		Password retrieval
			Reconnaissance
			Temporary admins
			Weak password

Legend:

- score is 0 - no risk identified
- score is 0 - no risk identified but some improvements detected
- score between 1 and 10 - a few actions have been identified
- score between 10 and 30 - rules should be looked with attention
- score higher than 30 - major risks identified

Le code couleur de PingCastle est simple : **Orange** signifie que les règles doivent être examinées avec attention (score entre 10 et 30), et **Jaune** indique quelques actions identifiées.



Analyse détaillée des règles "Stale Objects" (Hygiène de l'AD)

PingCastle a identifié **8 règles** correspondantes dans cette catégorie :

- **NTLMv1 ou LM autorisé (+15 points)** : Le niveau d'authentification LAN Manager autorise encore l'usage de protocoles obsolètes et vulnérables. C'est une faille critique car ces protocoles sont facilement interceptables et cassables par un attaquant.
- **Ajout de machines par des non-admins (+10 points)** : Les utilisateurs non-administrateurs peuvent joindre jusqu'à 10 ordinateurs au domaine par défaut. Cela permet potentiellement à un utilisateur (ou un attaquant ayant compromis un compte standard) d'introduire des machines non maîtrisées dans le domaine lab.local.
- **Déclaration de sous-réseau incomplète (+5 points)** : Deux adresses IP de contrôleurs de domaine ne sont pas rattachées à des sous-réseaux déclarés dans les sites et services AD. Cela peut engendrer des problèmes de réplication ou de lenteurs lors de la découverte des services par les clients.
- **Niveau fonctionnel inférieur à Windows Server 2012 R2 (Information)** : Le domaine utilise un niveau de compatibilité ancien. Pour un Samba-AD, c'est une information courante, mais cela limite l'usage de certaines fonctionnalités de sécurité modernes (comme les silos d'authentification).

- **Extensions de scripts dangereuses (Information)** : Certaines extensions de fichiers utilisées dans les campagnes de phishing peuvent être exécutées directement par un double-clic. Cela indique un manque de durcissement (hardening) au niveau des politiques de fichiers.
- **Configuration des services de terminaux (Information)** : Les GPO actuelles ne poussent pas les configurations de sécurité recommandées par Microsoft pour les services de bureau à distance (Terminal Services).

Privileged Accounts



Privileged Accounts rule details [4 rules matched on a total of 46]

Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 1	+ 20 Point(s)
The Recycle Bin is not enabled	+ 10 Point(s)
The group Schema Admins is not empty: 1 account(s)	+ 10 Point(s)
OU without the accidental deletion protection have been found	Informative rule

Analyse détaillée des règles "Privileged Accounts" (Sécurité des admins)

PingCastle a identifié **4 règles** correspondantes dans cette catégorie :

- **Absence du flag "Sensitive and cannot be delegated" (+20 points)** : Un compte administrateur ne possède pas la protection contre la délégation. C'est une vulnérabilité critique qui peut permettre à un attaquant de voler les jetons d'authentification de l'administrateur pour se déplacer latéralement sur le réseau.
- **La corbeille AD (Recycle Bin) n'est pas activée (+10 points)** : En cas de suppression accidentelle ou malveillante d'objets critiques (utilisateurs, groupes), je ne dispose pas d'un mécanisme de récupération rapide. Cela rend la restauration du domaine beaucoup plus complexe après un incident.
- **Le groupe "Schema Admins" n'est pas vide (+10 points)** : Un compte est présent dans le groupe des administrateurs du schéma. Par sécurité, ce groupe devrait être vide en permanence et n'accueillir des membres que temporairement lors de modifications structurelles de l'annuaire.
- **Unités d'organisation (OU) sans protection contre la suppression accidentelle (Information)** : Certaines OU ne sont pas verrouillées contre les erreurs de manipulation. Bien que ce soit une règle informative, cela expose le domaine à des interruptions de service si une branche entière de l'annuaire est supprimée par mégarde.

Anomalies analysis



Anomalies rule details [13 rules matched on a total of 73]

LAPS doesn't seem to be installed	+ 15 Point(s)
Last AD backup has been performed 10 day(s) ago	+ 15 Point(s)
The audit policy on domain controllers does not collect key events	+ 10 Point(s)
The number of DCs is too small to provide redundancy: 1 DC	+ 5 Point(s)
Hardened Paths have been modified to lower the security level	+ 5 Point(s)
DfHeuristics has not been set to enable the mitigation for CVE-2021-42291	Informative rule
No password policy for service accounts found (MinimumPasswordLength>=20)	Informative rule
The PowerShell audit configuration is not fully enabled	Informative rule
No GPO has been found which implements NetCense	Informative rule
The PreWin2000 compatible group contains "Authenticated Users"	Informative rule
No GPO has been found which disables LLMNR or at least one GPO does enable it explicitly	Informative rule
Authenticated Users can create DNS records	Informative rule
At least one DC is using Tls1.0 or Tls1.1	Informative rule

Analyse détaillée des règles "Anomalies" (Contrôles de sécurité)

PingCastle a identifié **13 règles** correspondantes dans cette catégorie, ce qui porte le score à **50/100** :

- **LAPS ne semble pas installé (+15 points)** : L'absence de *Local Administrator Password Solution* signifie que les mots de passe des administrateurs locaux sont probablement identiques ou statiques sur toutes vos machines. C'est une faille majeure facilitant le mouvement latéral après le compromis d'un premier poste.
- **Dernière sauvegarde AD effectuée il y a 10 jours (+15 points)** : la stratégie de sauvegarde est insuffisante ou non détectée. En cas d'attaque par ransomware ou de corruption de base de données, risque une perte de données importante.
- **Politique d'audit incomplète sur les DC (+10 points)** : Les contrôleurs de domaine ne collectent pas les événements de sécurité clés. En cas d'intrusion, il sera extrêmement difficile de retracer les actions de l'attaquant ou de comprendre l'origine de la compromission.
- **Absence de redondance (1 seul DC) (+5 points)** : Le domaine ne repose que sur un seul contrôleur de domaine. Toute panne matérielle ou logicielle sur ce serveur entraînera une interruption totale de l'authentification pour tout le réseau lab.local.
- **Hardened Paths modifiés (+5 points)** : La configuration des chemins durcis (UNC Hardening) a été modifiée, ce qui abaisse le niveau de sécurité lors de l'accès aux partages réseau critiques comme SYSVOL.

- **Protocoles réseau obsolètes (LLMNR / Tls1.0) (Informative)** : Le domaine autorise encore LLMNR et d'anciennes versions de TLS. Ces protocoles sont vulnérables aux attaques d'interception de type "Man-in-the-Middle".
- **Utilisateurs authentifiés peuvent créer des enregistrements DNS (Informative)** : N'importe quel utilisateur standard peut polluer votre zone DNS, ce qui peut être utilisé pour détourner du trafic réseau légitime vers des machines malveillantes.

Synthèse des Recommandations

Pour abaisser le score de risque sous la barre des 30 (zone Verte), les actions suivantes sont prioritaires :

- **Sécuriser les configurations techniques (Anomalies)** : Installer une solution de gestion des mots de passe locaux type LAPS et augmenter la fréquence des sauvegardes de l'Active Directory (actuellement à 10 jours).
- **Renforcer la surveillance et la disponibilité** : Activer les politiques d'audit avancées sur le contrôleur de domaine pour tracer les événements clés et envisager l'ajout d'un second contrôleur pour assurer la redondance du service.
- **Protéger les comptes à hauts privilèges** : Activer le flag "Sensitive and cannot be delegated" sur les comptes d'administrateurs et vider le groupe "Schema Admins" pour limiter l'exposition aux attaques de délégation.
- **Améliorer l'hygiène globale (Stale Objects)** : Désactiver le support de NTLMv1/LM et limiter le droit des utilisateurs non-admins à joindre des machines au domaine (valeur par défaut de 10 à réduire à 0).
- **Activer les protections natives** : Activer la corbeille Active Directory (Recycle Bin) pour permettre une récupération rapide en cas de suppression accidentelle d'objets.
- **Nettoyer les protocoles réseau** : Désactiver les protocoles obsolètes comme LLMNR et TLS 1.0/1.1 via GPO pour prévenir les attaques de type Man-in-the-Middle.